ZCAS University

BACHELOR OF SCIENCE IN CYBERSECURITY

BACHELOR OF SCIENCE IN CYBERSECURITY & CRIME SCIENCE

CIT3342 - HACKING THEORY AND PRACTICE

FINAL EXAMINATION

29TH NOVEMBER 2024

09:00 HRS-12:00HRS

TIME ALLOWED: WRITING – THREE HOURS

READING – 5 MINUTES

INSTRUCTIONS:

1. Section A: this question is **compulsory** and must be attempted.
2. Sections B: Answer **THREE (3)** questions from this section.
3. This examination paper carries a total of **100 marks**.
4. Candidates must **not turn this page** until the invigilator tells them to do so.

SECTION A: Question 1 is compulsory and must be attempted.

Question ONE

Part A: Penetration Testing

You are tasked with performing a penetration test on an e-commerce platform hosting sensitive customer data.

a) Describe the pre-engagement process for this penetration test, including legal and ethical considerations, scope definition, and agreement setup. **[5 Marks]**

b) Explain the steps in conducting reconnaissance (active and passive) on the target, specifying the types of information that can be gathered. **[5 Marks]**

c) During the exploitation phase, you discover a cross-site scripting (XSS) vulnerability. Outline how this vulnerability could be exploited and the potential risks to the platform. **[5 Marks]**

d) Summarize the elements to include in the final penetration test report for technical and non-technical stakeholders. **[5 Marks]**

Part B: Encrypted Data Exfiltration

You are investigating a suspected case of encrypted data exfiltration through an organization's VPN.

a) Define encrypted data exfiltration and discuss why it poses a unique challenge in cybersecurity. **[5 Marks]**

b) List and explain three methods attackers use to evade detection when exfiltrating data. **[5 Marks]**

c) Discuss detection strategies that cybersecurity professionals can use to identify encrypted exfiltration attempts. **[5 Marks]**

d) Highlight the ethical and legal considerations in monitoring encrypted traffic, particularly with privacy laws within Zambia. **[5 Marks]**

(Total: 40 marks)

SECTION B: Attempt any THREE questions in this section.

Question TWO

Information security relies on fundamental principles and the ability to address common threats.

a) Define and provide examples for the **Confidentiality**, **Integrity**, and **Availability** principles of information security. **[6 Marks]**

b) Identify and explain four types of ransomware attacks commonly encountered in information systems. **[4 Marks]**

c) Discuss the four categories of insider threats and provide one example for each. **[5 Marks]**

d) What is a vulnerability management framework, and how does it help organizations mitigate risks associated with known CVEs? **[5 Marks]**

(20 Marks)

Question THREE

Scenario: Your organization has detected a phishing campaign targeting employees through social media platforms.

a) Define spear-phishing and explain how it differs from general phishing. **[5 Marks]**

b) Describe techniques attackers may use to craft convincing phishing messages tailored to specific employees. **[5 Marks]**

c) What are the consequences of a successful phishing attack for an organization? **[5 Marks]**

d) Propose a multi-layered approach to prevent and mitigate the impact of phishing attacks. **[5 Marks]**

(20 Marks)

Question FOUR

Scenario: During an incident response, it was discovered that attackers used a brute-force attack to compromise the administrator password for a cloud-based service.

a) Explain the process of a brute-force attack and how attackers execute it. **[5 Marks]**

b) What are three types of authentication methods that could mitigate brute-force attacks? **[5 Marks]**

c) Outline the steps an organization can take to respond effectively to a successful brute-force attack. **[5 Marks]**

d) Discuss the role of security policies in reducing the risk of brute-force attacks on critical systems. **[5 Marks]**

(20 Marks)

Question FIVE

Scenario: As a cybersecurity analyst, you are investigating a potential security incident involving an organization's network. The initial information suggests that attackers may have conducted reconnaissance using the Nmap tool. Your task is to analyse the situation and propose a course of action based on the findings.

a) Define reconnaissance in cybersecurity and explain how it fits into the attack lifecycle. **[5 Marks]**

b) Describe three common scanning techniques used in Nmap (e.g., SYN scan, OS detection, and service detection) and the information each reveals. **[5 Marks]**

c) Explain how attackers might use Nmap scans to identify vulnerabilities in an organization's network. Provide an example. **[5 Marks]**

d) List and describe five defensive measures organizations can implement to detect Nmap scanning activities. **[5 Marks]**

(20 Marks)

(Total: 60 marks)

----------END OF EXAMINATION----------